Travaux Pratiques – Utiliser Wireshark pour examiner le trafic HTTP et HTTPS

Objectifs

Partie 1 : capturer et afficher le trafic HTTP

Partie 2 : capturer et afficher le trafic HTTPS

Contexte/scénario

Le protocole HTTP (HyperText Transfer Protocol) est un protocole de couche application qui présente des données via un navigateur web. Avec HTTP, aucune mesure de protection n'est appliquée pour les données échangées entre deux appareils qui communiquent.

Avec HTTPS, le chiffrement est assuré par un algorithme mathématique. Cet algorithme cache la véritable signification des données échangées. Pour cela des certificats, présentés ultérieurement dans ces travaux pratiques, sont utilisés.

Qu'il s'agisse de HTTP ou de HTTPS, il est recommandé d'échanger des données uniquement avec des sites web de confiance. Car même si un site utilise HTTPS cela ne signifie pas qu'il est sécurisé. Les hackers utilisent couramment HTTPS pour cacher leurs activités.

Au cours de ces travaux pratiques, vous allez explorer et capturer le trafic HTTP et HTTPS à l'aide de Wireshark.

Ressources requises

- Poste de travail virtuel CyberOps
- Connexion Internet

Instructions

Partie 1: Capturer et afficher le trafic HTTP

Dans cette partie, vous allez utiliser **tcpdump** pour capturer le contenu du trafic HTTP. Vous allez utiliser des options de commande pour enregistrer le trafic dans un fichier de capture (pcap) de paquets. Les enregistrements peuvent ensuite être analysés à l'aide de différentes applications qui lisent les fichiers pcap comme Wireshark.

© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Étape 1: Démarrez la machine virtuelle et connectez-vous.

Démarrez le poste de travail virtuel CyberOps. Utilisez les informations d'identification d'utilisateur suivantes :

Nom d'utilisateur : **analyst**

Mot de passe : **cyberops**

Étape 2: Ouvrez un terminal et lancez tcpdump.

a. Ouvrez une application de terminal et saisissez la commande **ip address**.

```
[analyst@secOps ~]$ ip address
```

b. Répertoriez les interfaces et leurs adresses IP affichées dans la sortie **ip address** .

c. Dans l'application de terminal, saisissez la commande **sudo tcpdump –i enp0s3 –s 0 –w httpdump.pcap**. Saisissez le mot de passe **cyberops** pour l'utilisateur analyst lorsque vous y êtes invité.

```
[analyst@secOps ~]$ sudo tcpdump –i enp0s3 –s 0 –w httpdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

Cette commande démarre tcpdump et enregistre le trafic réseau sur l'interface **enp0s3**.

L'option de commande **-i** permet de spécifier l'interface. Si cette option n'est pas spécifiée, la commande tcpdump capturera tout le trafic sur toutes les interfaces.

L'option de commande **-s** spécifie la longueur de la capture pour chaque paquet. Vous devez limiter la longueur de la capture (snaplen) avec la plus petite valeur possible de manière à capturer les informations de protocole qui vous intéressent. Lorsque la longueur est définie sur 0, elle est en fait définie avec la valeur par défaut 262144, pour des raisons de rétrocompatibilité avec les versions plus anciennes de tcpdump.

L'option de commande **-w** sert à écrire le résultat de la commande tcpdump dans un fichier. En ajoutant l'extension .pcap, les systèmes d'exploitation et les applications pourront lire ce fichier. Tout le trafic enregistré sera enregistré dans le fichier httpdump.pcap dans le répertoire de base de l'utilisateur analyst.

Utilisez les pages man de la commande tcpdump pour connaître l'utilisation des options de commande -s et -w.

d. Ouvrez un navigateur web à partir de la barre de lancement dans le poste de travail CyberOps VM. Accédez à **http://www.altoromutual.com/login.jsp**

Étant donné que ce site web utilise le protocole HTTP, le trafic n'est pas chiffré. Cliquez sur le champ de nom d'utilisateur pour afficher le message d'avertissement.

e. Saisissez le nom d'utilisateur **Admin** avec le mot de passe **Admin** et cliquez sur **Login**.

© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

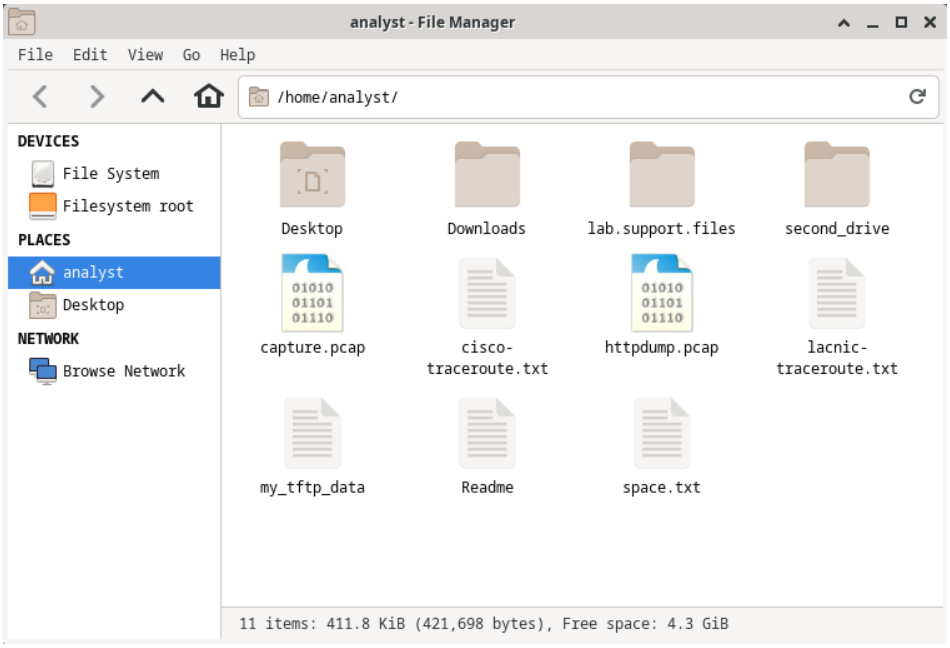
f. Fermez le navigateur Web.

g. Revenez à la fenêtre de terminal où tcpdump est en cours d'exécution. Appuyez sur **Ctrl+C** pour arrêter la capture des paquets.

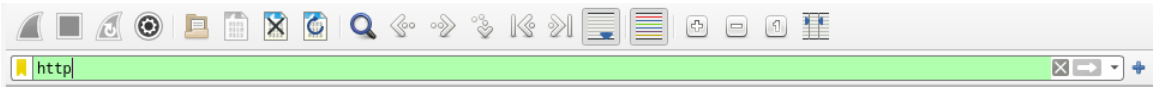
Étape 3: Affichez la capture HTTP.

La commande tcpdump, exécutée à l'étape précédente, a enregistré la sortie dans un fichier nommé httpdump.pcap. Ce fichier se trouve dans le répertoire de base de l'utilisateur **analyst**.

a. Cliquez sur l'icône du gestionnaire de fichiers sur le bureau et accédez au dossier de base pour l'utilisateur **analyst**. Double-cliquez sur le fichier **httpdump.pcap**, dans la zone de dialogue Ouvrir avec, faites défiler jusqu'à Wireshark, puis cliquez sur **Open**.

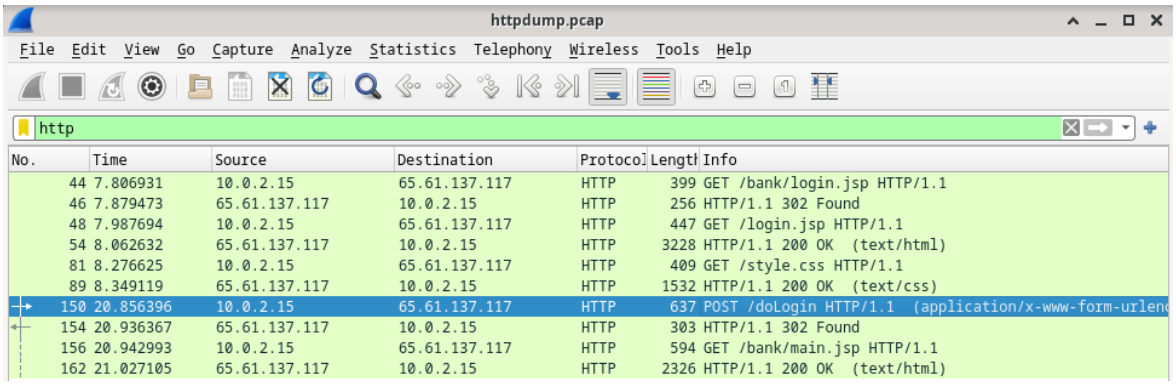


b. Dans l'application Wireshark, recherchez **http** et cliquez sur **Apply**.

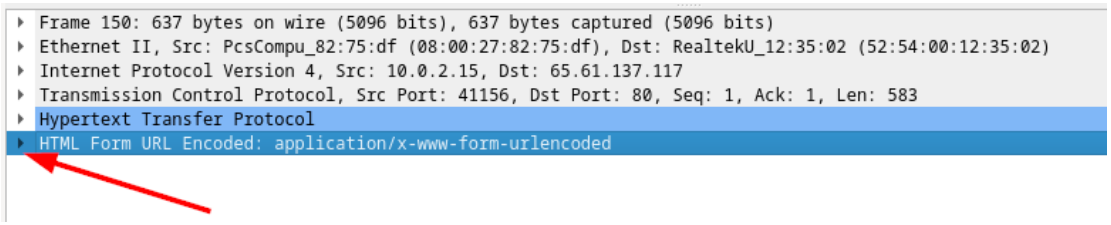


© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

c. Naviguez dans les différents messages HTTP, puis sélectionnez le message **POST**.



d. Le message s'affiche dans la fenêtre inférieure. Développez la section **HTML Form URL Encoded: application/x-www-form-urlencoded**.



Quelles sont les deux informations affichées ?

e. Fermez l'application Wireshark.

Partie 2: Capturer et afficher le trafic HTTPS

Vous allez maintenant utiliser tcpdump depuis la ligne de commande d'un poste de travail Linux pour capturer le trafic HTTPS. Après avoir démarré tcpdump, vous allez générer le trafic HTTPS et tcpdump enregistrera le contenu du trafic réseau. Ce contenu sera également analysé à l'aide de Wireshark.

Étape 1: Lancez tcpdump dans un terminal.

a. Dans l'application de terminal, saisissez la commande **sudo tcpdump –i enp0s3 –s 0 –w httpsdump.pcap**. Saisissez le mot de passe **cyberops** pour l'utilisateur analyst lorsque vous y êtes invité.

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s3 -s 0 -w httpsdump.pcap
[sudo] password for analyst:
tcpdump: listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
```

© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

Cette commande démarre tcpdump et enregistre le trafic réseau sur l'interface **enp0s3** du poste de travail Linux. Si votre interface est différente de celle d'enp0s3, modifiez-la lorsque vous utilisez la commande ci-dessus.

Tout le trafic enregistré sera enregistré dans le fichier **httpsdump.pcap** dans le répertoire de base de l'utilisateur analyst.

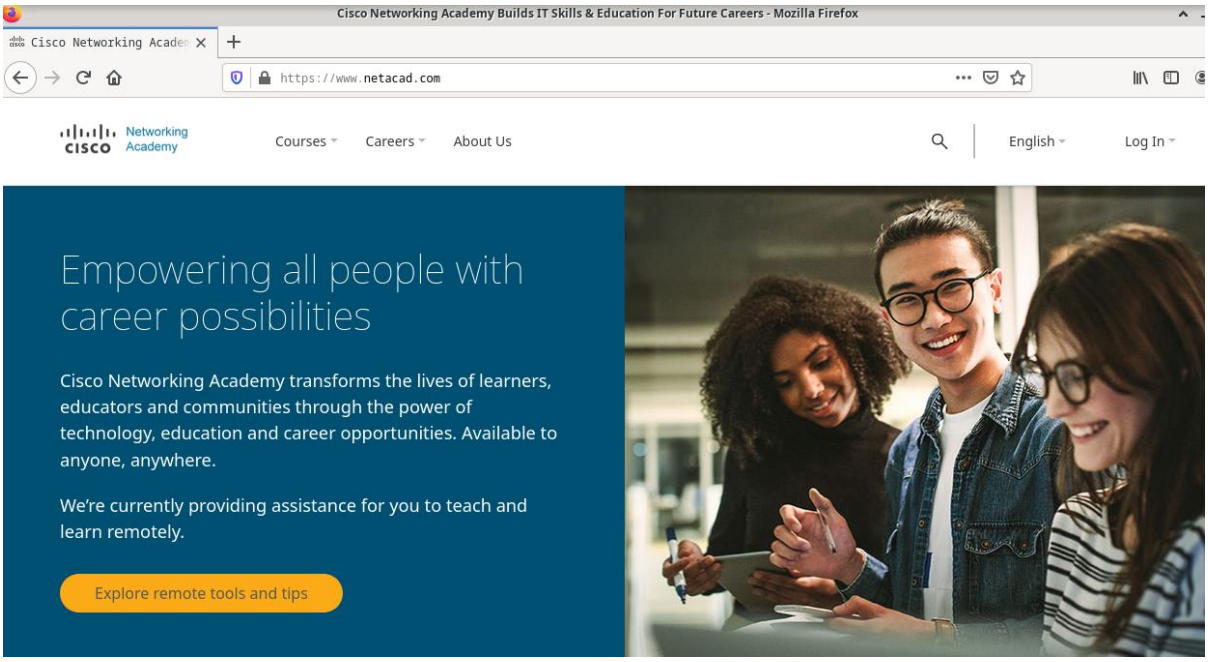
b. Ouvrez un navigateur web à partir de la barre de lancement dans le poste de travail CyberOps VM. Accédez à www.netacad.com.

Remarque: Si vous recevez une page Web «Échec de la connexion sécurisée», cela signifie probablement que la date et l'heure sont incorrectes. Mettez à jour le jour et l'heure à l'aide de la commande suivante, en changeant le jour et l'heure actuels:

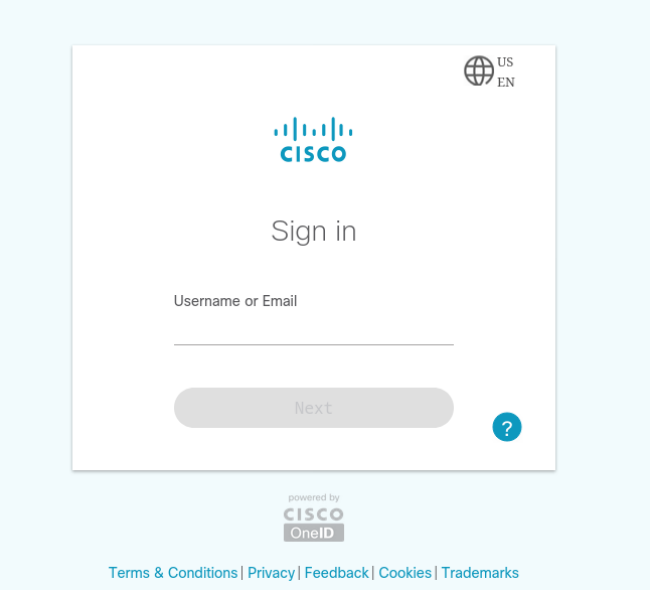
```
[analyste @secOps ~] $ sudo date -s « 12 MAI 2020 21:38:20
```

Que remarquez-vous à propos de l'URL du site web ?

c. Cliquez sur **Log in**.



d. Saisissez votre nom d'utilisateur et votre mot de passe pour NetAcad. Cliquez sur **Suivant**.



e. Fermez le navigateur web dans la VM.

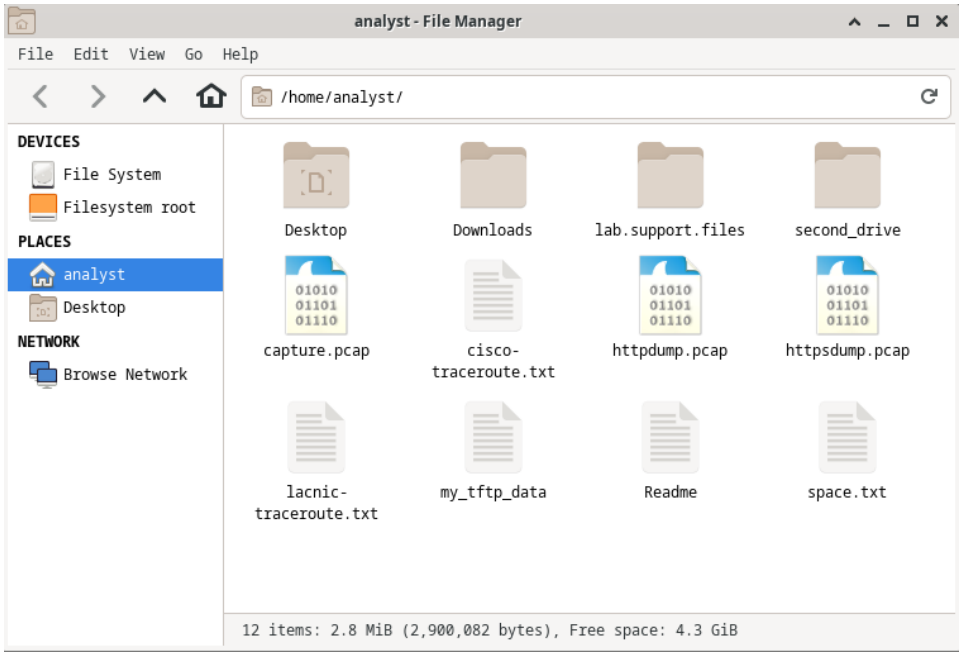
f. Revenez à la fenêtre de terminal où tcpdump est en cours d'exécution. Appuyez sur **Ctrl+C** pour arrêter la capture des paquets.

Étape 2: Affichez la capture HTTPS.

La commande tcpdump exécutée à l'étape 1 a enregistré la sortie dans un fichier nommé httpsdump.pcap. Ce fichier se trouve dans le répertoire de base de l'utilisateur **analyst**.

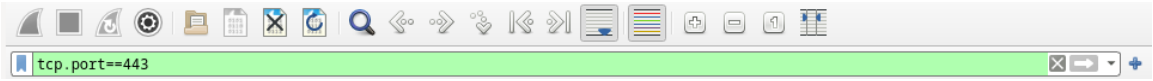
© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

a. Cliquez sur l'icône du système de fichiers sur le bureau et recherchez le dossier de base de l'utilisateur analyst. Ouvrez le fichier **httpsdump.pcap**.

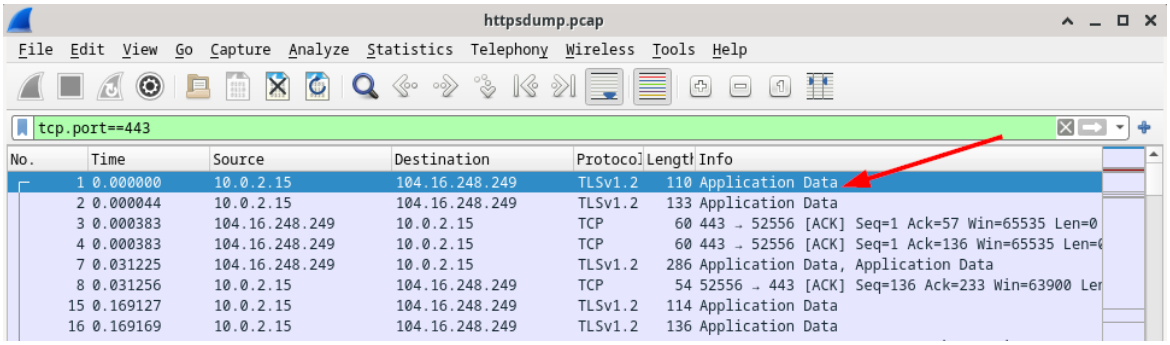


b. Dans l'application Wireshark, agrandissez la fenêtre de capture verticalement, puis filtrez par trafic HTTPS via le port 443.

Saisissez **tcp.port==443** comme filtre, puis cliquez sur **Apply**.



c. Naviguez parmi les différents messages HTTPS, puis sélectionnez un message **Application Data**.

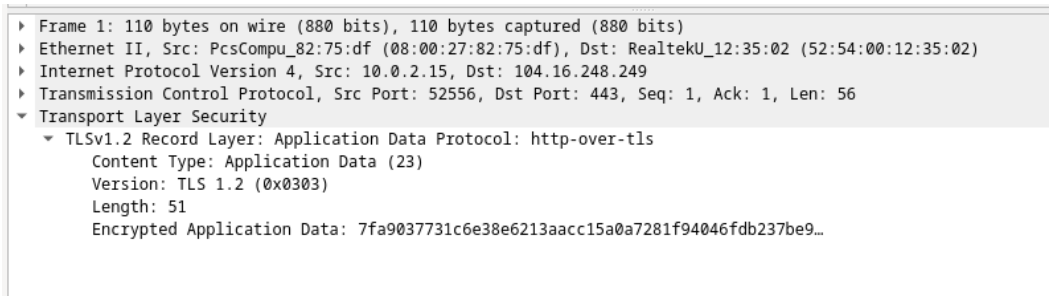


d. Le message s'affiche dans la fenêtre inférieure.

Par quoi la section HTTP qui était dans le fichier de capture précédent a-t-elle été remplacée ?

© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco

e. Développez complètement la section **Secure Sockets Layer**.



f. Cliquez sur **Encrypted Application Data**.

Les données d'application sont-elles en texte clair ou dans un format lisible ?

g. Fermez toutes les fenêtres et arrêtez la machine virtuelle.

Questions de réflexion

1. Quels sont les avantages d'utiliser HTTPS plutôt que HTTP ?
2. Tous les sites web qui utilisent le protocole HTTPS sont-ils considérés comme sécurisés ?

© 2017 - aa Cisco et/ou ses filiales. Tous droits réservés. Document public de Cisco